FOR THE CISO

Automated containment for AI-speed attacks in 90 days

> **Decision needed:** approve a written policy that lets automation contain a short list of near-certain attacks on low-risk targets without waiting for an analyst. Sign by day 30.

Problem. AI-assisted attackers reach lateral movement in minutes (fastest observed eCrime breakout: 27 seconds, CrowdStrike). When every containment needs an analyst decision, response arrives after the damage.

What changes by day 90.

- **9 detections contain automatically** on workstations, standard users and human cloud accounts: decoy and canary hits, credential theft, MFA fatigue, machine-speed reconnaissance, ransomware preparation, cloud logging disabled, stolen cloud credentials, and EDR tampering confirmed by a second signal.
- **All other high-severity alerts** get an AI-agent investigation and recommendation in under 5 minutes. Analysts still decide.
- **Exposure reduced:** phishing-resistant MFA for all admins, edge device management off the internet, actively exploited vulnerabilities on exposed systems patched within 72 hours.

What could go wrong, and the control.

RISK	CONTROL
Automation isolates the wrong target	Low-risk targets only; critical systems and accounts go to a human. 2 weeks recommend-only first. One-click undo.
Bad rule or vendor outage causes mass action	Rate limits stop automation and page on-call; circuit breaker pauses it if many EDR sensors fail at once.
An attacker triggers our automation against us	Mass decoy hits become one investigation, not mass isolation. Text planted for the AI agent never triggers containment.
The AI agent makes a bad call	Recommend-only until ≥ 95% agreement with analysts over 30+ cases, zero harmful calls, per action type.
Users don't know why they were cut off	Every action logged; help desk answers "did security do this to me?" in under a minute.

What we need from you

Sign the containment policy	Day 30
Mandate phishing-resistant MFA for admins	Day 1
Network team: edge management off the internet	Days 1–30
App owners: 15 min each to approve server isolation	Days 31–60
API access for agents and the automation platform	Day 1

How we'll measure it

Detect-to-contain, simulated attack	< 5 min
Alert to agent investigation	< 5 min
Detections containing automatically	9
EDR coverage in block mode	> 95%
Admins on phishing-resistant MFA	100%
Edge management exposed to internet	0

Cost: existing EDR, SIEM, identity provider and automation platform; no new tooling assumed. Main cost is engineering time. **Next quarter, not in scope:** AI agent kill switch, phishing automation, network-layer quarantine, cloud server isolation, SaaS detections, data-theft detection, threat hunting, hypervisor monitoring.

FOR ENGINEERING

Implementation detail

IDs (e.g. A-03) map to `catalog/capabilities.yaml` in the framework repo, which holds the full spec for each item.

1. Phase checklist

Days 1–30: authorize and see

ITEM	DONE WHEN	ID
Containment policy	Signed; lists each automated action and the asset/identity tiers it applies to	F-01
Asset tiers	All workstations tagged A in the EDR; untagged servers default to B	F-02
Identity tiers	Exclusion group exists for tier C (break-glass, service, sync, cloud admin, automation roles); automation reads it	F-03
Action log	Help desk can look up any user/host and see every action, trigger, state and undo step	F-12
Must-have logs	All sources in section 6 flowing, lag < 5 min on a dashboard, silence alert per source	F-06
Exposure inventory	Internet-facing services listed with owners; known-exploited vulns tracked to 72 h SLA	F-09
Edge lockdown	No edge management interface reachable from the internet; VPN requires SSO + MFA	H-08
Decoys and canaries	Decoys on all servers and a workstation sample, canary AD user + SPN, recommend-only	A-01, A-02
Admin MFA rollout	Phishing-resistant MFA rollout started for privileged accounts	H-01
Blind spot agent	Daily read-only report: silent sources, unmanaged hosts, stale tables	agents/

Days 31–60: build actions, learn noise

ITEM	DONE WHEN	ID
Action safety	Tier check at run time, undo + bulk undo, rate limits per rule and action type paging P1, all writes to action log	F-04
Six actions	Isolate host, kill process, network block, revoke sessions, disable account, reset password + MFA: each run and undone on a test target	ACT-*
EDR posture	> 95% coverage, prevent mode, anti-tamper, broad exclusions reviewed	F-05
Decoys to auto	2 clean weeks, mass-hit breaker in place	A-01, A-02
Tier 1 in recommend	Credential theft, MFA fatigue, recon burst, ransomware precursors producing recommendations	A-03, A-06, A-13, A-15
Triage agent	Write-up on every EDR high/critical, risky sign-in, new MFA method, server shell	D-01–D-04
Tuning	Exceptions drafted narrowly with owner and expiry from day 31	agents/
Server tiers	Owners answered the isolate question; no answer = stays B	F-02

Days 61–90: cloud, edge, go automatic

ITEM	DONE WHEN	ID
Cloud actions	Revoke cloud credentials (tier-aware) and restore logging tested in each cloud	ACT-06, ACT-12

ITEM	DONE WHEN	ID
Cloud detections	Logging disabled, creds used outside provider / unused region, new privilege or root/break-glass use	A-08, A-12, D-06
Edge monitoring	Edge admin sign-ins and config changes in SIEM, routed to triage	D-12
EDR tampering	Corroboration rule and circuit breaker tested	A-04
AI agent inventory	Agents that can write or execute listed with identity, owner and logs	F-10
Admin MFA	100% of privileged accounts phishing-resistant	H-01
Graduation	Rules passing graduation criteria (section 4) switched to auto for tier A	—
Simulation	Decoy read, credential theft, recon burst, MFA burst, cloud trail disable; detect-to-contain recorded	F-08

2. Detections

"Auto" applies to tier A targets only. Tier B gets kill process / network block / revoke + page. Tier C always pages.

DETECTION	TRIGGER	NEEDS	RESPONSE	DAY 90
Decoy / canary credential A-01	Read of a decoy file by a content-opening process, or use of an embedded canary credential	EDR file-read or object-access auditing	Isolate host, revoke reader's sessions	**Auto**
Canary AD account A-02	Any auth attempt or Kerberos service ticket request for a canary user/SPN	DC security logs	Isolate source host	**Auto**
Credential theft A-03	EDR high-confidence: LSASS dump (incl. comsvcs), SAM/SYSTEM hive save, DCSync from non-DC, browser credential theft	EDR	Isolate, revoke sessions of logged-on users, reset creds, block C2	**Auto**
MFA fatigue A-06	N denied/ignored pushes in a short window, then approval from new IP/device	IdP sign-in + MFA events	Revoke sessions, remove MFA methods added in 24 h, reset	**Auto**
Recon burst A-13	≥ N distinct discovery commands in 60 s from one process tree (Windows and Linux lists; metadata endpoint from shells)	EDR process telemetry	Isolate workstation, revoke session; servers → triage	**Auto (workstations)**
Ransomware precursors A-15	Shadow copy/backup deletion, recovery disabled, mass stop of security/backup/DB services	EDR	Isolate, disable user, network block	**Auto**
Logging disabled A-08	Cloud trail stopped/deleted/updated, diagnostic settings removed, threat detection disabled, security log cleared	Cloud control plane, DC/host logs	Restore logging (always), revoke actor's cloud creds per tier	**Auto**
Stolen cloud creds A-12	Threat-detection finding: workload creds used outside provider, or activity in unused region/account	GuardDuty / Defender for Cloud	Revoke active sessions on the role, page	**Auto**
EDR tampering + 2nd signal A-04	Tamper alert, sensor stop, vulnerable driver, or sensor silent while host is on network, plus another detection on same host/user within 60 min	EDR health, DHCP/DNS/IdP device logs	Revoke sessions, attempt isolation, page	**Auto if graduated**

DETECTION	TRIGGER	NEEDS	RESPONSE	DAY 90
EDR tampering alone	Any of the above without corroboration	as above	Triage agent decides	**Recommend**
EDR high/critical D-01	Any EDR high/critical not covered above	EDR	Agent investigates, recommends	**Recommend**
Risky sign-in D-02	IdP risk detection, new device + new ISP, token replay, anonymizing infrastructure	IdP sign-in + risk	Agent recommends revoke/reset	**Recommend**
New MFA method / reset D-03	MFA registered from unseen device/IP, or help-desk reset then new-device sign-in within 24 h	IdP audit	Agent recommends remove method, revoke	**Recommend**
Server spawns shell D-04	Web/app/DB process spawning cmd, PowerShell, sh/bash; new script in web dir	EDR	Agent recommends isolate/kill/block	**Recommend**
New privilege D-06	New admin role, OAuth consent, SP secret, cloud key/admin policy, federation change; root or break-glass use = P1	IdP audit, cloud control plane	Agent recommends revert + revoke actor	**Recommend**
Edge admin/config change D-12	New edge admin, admin sign-in from outside mgmt network, config/firmware change without ticket	Edge device logs	Agent recommends disable admin, block IP	**Recommend**
Prompt injection in evidence	Instructions aimed at an AI/analyst found in alert data	—	Raise severity, human + research decide; never contain on this alone	**Human**

3. Response actions

ACTION	WHAT IT DOES	UNDO	AUTO SCOPE AT DAY 90
Isolate host (EDR)	Network containment, EDR channel kept open	Release	Tier A hosts
Kill process	Terminate tree, quarantine binary	Restore file	Tier A/B hosts
Network block	Domain/IP/URL at DNS, firewall/proxy, email gateway; hash in EDR	Remove block	New/rare indicators; never business-critical domains or shared IPs
Revoke sessions	Kill IdP sessions and refresh tokens (assumes SaaS via SSO; verify top apps honor it)	User signs in again	Tier A identities
Disable account	Disable in source of truth; always paired with revoke (issued tokens outlive a disable)	Re-enable	Tier A humans
Reset password + MFA	Force reset, remove recently added MFA methods; re-enroll via help desk	Help desk re-enroll	Tier A identities
Revoke cloud creds	(1) revoke active sessions, (2) deactivate key, (3) deny-all policy	Detach / reactivate	Humans: 1–3. Workloads: 1 only. Tier C: none
Restore cloud logging	Re-enable trail, diagnostic settings, threat detection	n/a	Always

4. Safety mechanics

CONTROL	SETTING
Recommend period	Every rule ≥ 2 weeks recommend-only on real traffic before auto
Rule graduation	Projected ≤ 1 false positive/month (or each covered by a narrow exception); action tested; fired at least once (real or simulated); listed in the signed policy
Agent graduation	Per action type and tier: ≥ 30 reviewed recommendations, ≥ 95% agreement, zero harmful, passes prompt-injection test set
Rate limits	Per rule and per action type (isolate, disable, revoke, block). Hitting a limit stops automation and pages P1
EDR circuit breaker	> ~2% of sensors (or N hosts) silent within an hour → infrastructure incident, no automated action
Decoy mass-hit breaker	Decoys tripped on > 3 hosts within 15 min → stop per-host containment, one P1 incident, find shared source
Decoy read filter	Count shells, script engines, editors, archivers, AI agent processes; exclude backup, AV, indexer, Explorer preview/thumbnail
Prompt injection	Containment targets come only from structured alert entities and independent telemetry, never free text
Missing data	Untagged host = B, untagged identity = B, stale table row = missing
Exceptions	Narrowest match (hash + host + account first), owner, reason, expiry ≤ 12 months, human-approved
Action log fields	Time, target, action, trigger (rule/agent/analyst), case link, state (active/undone), undo step

5. Tiers

TIER	HOSTS	IDENTITIES	CLOUD PRINCIPALS	AUTOMATION MAY
A	All workstations, non-prod servers	Standard users	Human users and roles	Run any action
B	Servers (default), owner-confirmed prod	Executives, IT admins	Workload, CI/CD, service roles	Kill process, block, revoke sessions; page for the rest
C	DCs, hypervisors, IdP/sync, PKI, security tools, backup, core network, OT	Break-glass, service, sync accounts	Root, org admin, security tooling, automation roles	Nothing. Page only

6. Logs

Must have (days 1–30)

- EDR alerts and telemetry, sensor health, console audit
- Decoy read auditing (EDR file reads or object-access SACL)
- Second "host alive" source: DHCP, DNS or IdP device sign-ins
- IdP sign-ins incl. MFA events, audit log, risk detections
- Domain controller security logs
- Edge device admin sign-ins and config changes

Collect now (by day 60)

- DNS queries
- Email gateway
- VPN / remote access sign-ins
- AI agent platform logs (agents that can write or execute)
- Automation platform audit

All sources: < 5 min ingest lag, silence alert, ≥ 90 days searchable.

- Cloud control plane and threat detection findings (if cloud)

7. Data tables

TABLE	BUILT FROM	REFRESH	IF ROW MISSING
Asset tiers	EDR inventory + role signals; agent classifies servers; owners confirm	Daily	Tier B
Identity tiers	IdP + HR + cloud IAM; agent flags non-human accounts	Daily	Tier B
Exceptions	Agent drafts, human approves, script expires	Daily	No exception
Decoy registry	Deployment script; weekly health check	Weekly	—
Exposure inventory	External scan + cloud public IPs, joined with KEV	Weekly / KEV daily	Alert
Cloud accounts and regions	Cloud org APIs; owner confirms region allowlist	Weekly	Region disallowed
AI agent inventory	EDR, OAuth grants, agent platforms	Weekly	Unapproved

Scripts build, agents propose, humans approve, automation reads. Tightening may be automatic; loosening (tier C, new exception) needs a human. Every table alerts if it stops refreshing.

8. Edge devices

1. **Inventory** every exposed VPN, firewall, file transfer and remote access gateway: vendor, version, owner, what it authenticates against.
2. **Lock down:** management off the internet, VPN via SSO + MFA, named admins only, unused portals off.
3. **Patch** known-exploited vulnerabilities in ≤ 72 h, or mitigate / restrict / take offline with a signed exception.
4. **Assume compromise** when a known-exploited bug hits an exposed device: run the vendor integrity checker, review admin accounts, config, files and VPN sessions since disclosure, reset credentials that passed through it (VPN users in the window, the device's LDAP account).
5. **Watch** admin sign-ins, config/firmware changes and admin account changes; route to triage.

9. Agents

AGENT	STARTS	DOES	PERMISSION
Blind Spot Detector	Day 1	Silent log sources, unmanaged hosts, detect-only policies, stale tables	Read-only
Triage	Day 31	Investigates alerts, classifies entry vector, runs blast-radius sweep, recommends actions	Recommend → auto per action type after graduation
Data Steward	Day 31	Classifies unknown servers and accounts, drafts owner questions	Proposes table changes
Alert Tuner	Day 31	Finds noise, drafts narrow exceptions, runs graduation reviews	Proposes exceptions

Skill packs, tool interface and permission ladder: `agents/` in the framework repo.